HelioVolt Information Security Policy

Document ID: HV-SEC-003 | Version 3.0 | Effective: Jan 1, 2026 | Owner: James Park (CISO) | Classification: Internal

1. Purpose: Protect customer telemetry (13-month retention), PII, and production in AWS us-east-1 and eu-central-1. Comply with SOC 2 Type II (audit June 1-30, 2026) and GDPR for Berlin/EU shard.

2. Access Control: Least privilege. AWS default role ReadOnly; prod deploy needs break-glass via Okta + YubiKey 5C + Slack approval in #eng-approvals. GitHub Enterprise branch protection on main: 2 reviews required. Okta MFA via Okta Verify mandatory; SMS codes are NOT allowed. Dormant accounts disabled after 45 days. Offboarding revokes all access within 4 hours.

3. Encryption: TLS 1.2+ in transit (mqtt.heliovolt.fake:8883 uses TLS). AES-256 at rest (RDS, S3 hv-prod-* with SSE-KMS key alias hv-prod-key). Laptops require FileVault (Mac) / BitLocker (Win). USB drives prohibited without CISO exception SEC-EXEMPT (max 30 days).

4. Logging: CloudTrail + CloudWatch retained 90 days hot, S3 hv-prod-logs 13 months. Datadog alerts to PagerDuty + #eng-alerts. SEV1 page for error rate >5% or down >5 min. No customer PII in logs; mask emails as j***@example.

5. Vulnerability Management: Dependabot auto-PRs weekly. Critical CVSS ≥9 patched in 48h, High in 14 days. Pen test finding PT-44 (MQTT auth bypass firmware <2.3.5) must be patched by April 30, 2026. Annual pen test by BishopFake Labs.

6. Acceptable Use: No public Wi-Fi without VPN vpn.heliovolt.fake. No production data on personal devices. AI tools: customer code/telemetry must NOT be pasted into public LLMs; use internal HV-GPT only. Report phishing via Phish Alert button within 1 hour to security@heliovolt.fake.

7. Contacts: security@heliovolt.fake | Slack #security | IT Helpdesk ext 4357 | CISO James Park, james.park@heliovolt.fake.